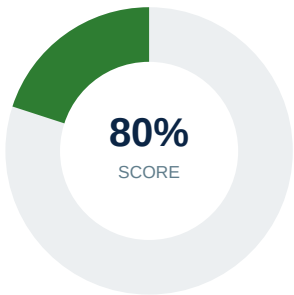


Security Audit Report

Web Application & Infrastructure Assessment



Target: <https://growlity.com/blog/brsr-principles-guide-india>
Prepared for: Client
Scan Date: 31 August 2026, 15:37
Overall Risk Status: **CRITICAL RISK**

Total Checks	Passed	Failed	Critical	High	Medium	Low
52	42	10	1	1	2	6

This report is confidential and intended solely for the addressed client. It summarizes automated findings from an external, black-box security scan and should be supplemented with manual penetration testing for a complete risk assessment.

1. Executive Summary

The assessment identified **10** issue(s) out of **52** checks performed, resulting in a security score of **80%** and an overall risk rating of **CRITICAL RISK**. There are **1 critical** and **1 high** severity finding(s) that should be prioritized for remediation.

2. SSL / TLS & Certificate Audit

Parameter	Result
TLS Version	TLSv1.3
Cipher Suite	TLS_AES_256_GCM_SHA384
Hostname Verification	PASS
Self-Signed	NO
Valid From	Jul 18 05:50:00 2026 GMT
Valid Until	Oct 16 06:49:58 2026 GMT
Days Remaining	45
Issuer	countryName=US, organizationName=Google Trust Services, commonName=WE1
Subject	commonName=growlity.com
Subject Alt. Names (SAN)	growlity.com, *.growlity.com

3. DNS, DNSSEC & Domain Audit

Parameter	Result
A Records	104.21.65.81, 172.67.189.104
AAAA Records	2606:4700:3031::ac43:bd68, 2606:4700:3035::6815:4151
MX Records	20 mx2.zoho.com., 50 mx3.zoho.com., 10 mx.zoho.com.
NS Records	colette.ns.cloudflare.com., kolton.ns.cloudflare.com.
CAA Records	None (finding)
DNSSEC Enabled	YES
WHOIS Registrar	GoDaddy.com, LLC
Domain Expiration	2028-05-26 08:15:37+00:00
Days To Expiry	633

4. Security Issues & Recommendations

Severity	Check	Details	Recommendation
CRITICAL	Website Availability	Website returned HTTP 403.	Verify website availability and server configuration.
HIGH	HTTP to HTTPS Redirect	HTTP does not correctly redirect to HTTPS.	Configure a permanent HTTP to HTTPS redirect.
MEDIUM	X-Frame-Options	X-Frame-Options header is missing.	Configure a proper X-Frame-Options header.
MEDIUM	DNS - CAA Record	No CAA record found - any public CA can issue certs for this domain.	Add a CAA record restricting which Certificate Authorities may issue certificates.
LOW	Information Disclosure - server	Server technology information exposed: cloudflare	Remove unnecessary technology/version information from HTTP headers.
LOW	Security.txt (RFC 9116)	No security.txt file found.	Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
LOW	Cross-Origin-Opener-Policy	Cross-Origin-Opener-Policy header is missing.	Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Resource-Policy	Cross-Origin-Resource-Policy header is missing.	Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Embedder-Policy	Cross-Origin-Embedder-Policy header is missing.	Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
LOW	X-Permitted-Cross-Domain-Policies	X-Permitted-Cross-Domain-Policies header is missing.	Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

5. Successful Security Checks

Check	Severity	Details
TLS Version	INFO	Secure TLS version detected: TLSv1.3
SSL Certificate	INFO	Valid TLS certificate was successfully retrieved.
TLS Cipher	INFO	Negotiated cipher: TLS_AES_256_GCM_SHA384
Certificate Hostname Match	INFO	Certificate hostname matches the requested domain (SAN/CN verified).
Legacy Protocol Support - TLSv1.0	INFO	Server correctly rejects TLSv1.0.
Legacy Protocol Support - TLSv1.1	INFO	Server correctly rejects TLSv1.1.
Protocol Support - TLSv1.2	INFO	Server supports TLSv1.2.
Protocol Support - TLSv1.3	INFO	Server supports TLSv1.3.
HSTS	INFO	Header present: max-age=31536000; includeSubDomains; preload
Content Security Policy	INFO	Header present: frame-ancestors 'self' https://growlity.com
X-Content-Type-Options	INFO	Header present: nosniff
Referrer Policy	INFO	Header present: same-origin, strict-origin-when-cross-origin
Permissions Policy	INFO	Header present: camera=(self), microphone=(self), geolocation=(self), payment=(self), usb=(), interest-cohort=()
CSP Strength	INFO	CSP does not use unsafe-inline, unsafe-eval, or an obvious wildcard source.
HSTS Strength	INFO	HSTS configured with sufficient max-age, includeSubDomains and preload.
Clickjacking Protection	INFO	Framing is restricted via X-Frame-Options and/or CSP frame-ancestors.
CORS Configuration	INFO	No permissive CORS wildcard detected.
Cookie Security	INFO	No cookies were set during the initial response.
HTTP Methods	INFO	No explicit Allow header exposing methods.
Sensitive Path Exposure	INFO	No tested sensitive paths returned HTTP 200.
Sensitive / Internal Link Exposure	INFO	No internal, staging or admin/config links were found in the page's outbound links.
Mixed Content	INFO	No obvious HTTP resource references detected.
Cache-Control	INFO	Cache-Control: private, max-age=0, no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Subresource Integrity (SRI)	INFO	No external scripts missing SRI (or none detected).
Robots.txt	INFO	No robots.txt found (nothing to disclose).
HTTP Protocol Version	INFO	Negotiated protocol (via requests/urlib3): HTTP/1.1. Server advertises Alt-Svc: h3=":443"; ma=86400 (h3/h2 support).
DNS - Name Servers	INFO	NS records: colette.ns.cloudflare.com., kolton.ns.cloudflare.com.
DNS - SPF Record	INFO	SPF record found in TXT records.
DNSSEC	INFO	DNSSEC is enabled for this domain.
Domain Expiry (WHOIS)	INFO	Domain registered until 2028-05-26 08:15:37+00:00 (633 days remaining).
Certificate Transparency Logs	INFO	Could not retrieve CT log data (crt.sh unavailable or rate-limited).
Version Disclosure	INFO	No specific software version numbers were disclosed in response headers.
HTTP TRACE Method	INFO	Server does not permit TRACE requests (HTTP 405).
Directory Listing	INFO	No directory listing detected on commonly probed paths.
Open Redirect	INFO	No open redirect behavior detected on commonly probed parameters.
Password Field Autocomplete	INFO	No password input fields detected on this page.
Exposed Secrets in Page Source	INFO	No obvious credential/key patterns detected in page source.
Cryptomining / Known Malicious Script Source	INFO	No script tags referencing known malicious/cryptomining domains were found.
Obfuscated Script / Hidden Iframe Patterns	INFO	No obfuscated script or hidden-iframe patterns detected in page source.
Unsolicited Cross-Domain Redirect	INFO	No meta-refresh redirect detected.

Check	Severity	Details
Self Signed Certificate	INFO	Certificate is not self-signed.
Certificate Expiry	INFO	Certificate has 45 days remaining.

6. Sensitive Path Enumeration

Path	HTTP Status	Risk	Exposed
.env	403	INFO	NO
.git/config	403	INFO	NO
config.json	403	INFO	NO
config.php	403	INFO	NO
debug	403	INFO	NO
actuator	403	INFO	NO
phpinfo.php	403	INFO	NO
server-status	403	INFO	NO
backup.zip	403	INFO	NO
backup.sql	403	INFO	NO
.DS_Store	403	INFO	NO
composer.json	403	INFO	NO
package-lock.json	403	INFO	NO
webpack.config.js	403	INFO	NO
docker-compose.yml	403	INFO	NO
database.sql	403	INFO	NO
dump.sql	403	INFO	NO
admin	403	INFO	NO
admin/	403	INFO	NO
debug.log	403	INFO	NO
error.log	403	INFO	NO
swagger.json	403	INFO	NO
swagger-ui.html	403	INFO	NO
graphql	403	INFO	NO
.htaccess	403	INFO	NO
wp-config.php	403	INFO	NO
.well-known/security.txt	403	INFO	NO
.git/HEAD	403	INFO	NO
.env.local	403	INFO	NO
.env.production	403	INFO	NO
.env.backup	403	INFO	NO
credentials.json	403	INFO	NO
secrets.yml	403	INFO	NO
secrets.yaml	403	INFO	NO
.aws/credentials	403	INFO	NO
id_rsa	403	INFO	NO
id_rsa.pub	403	INFO	NO
.npmrc	403	INFO	NO
.idea/workspace.xml	403	INFO	NO
.vscode/settings.json	403	INFO	NO
web.config	403	INFO	NO
vendor/composer/installed.json	403	INFO	NO
storage/logs/laravel.log	403	INFO	NO

Path	HTTP Status	Risk	Exposed
wp-content/debug.log	403	INFO	NO
.well-known/openid-configuration	403	INFO	NO
server.key	403	INFO	NO
server.pem	403	INFO	NO

7. Cookie Security

No cookies were observed during this scan - the initial response did not include any **Set-Cookie** headers, so there is nothing to assess here.

8. Prioritized Recommendations

1. Verify website availability and server configuration.
2. Configure a proper X-Frame-Options header.
3. Remove unnecessary technology/version information from HTTP headers.
4. Configure a permanent HTTP to HTTPS redirect.
5. Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
6. Add a CAA record restricting which Certificate Authorities may issue certificates.
7. Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
8. Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
9. Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
10. Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

9. AI Overall Review & Suggestions

The overall security posture of the target site is currently compromised by a critical availability issue, despite a moderate baseline score of 80%. The most immediate concern is that the website is returning an HTTP 403 Forbidden error, which effectively blocks legitimate users and search engines from accessing the content. This is not merely a security misconfiguration but a functional outage that halts business operations and damages user trust. While the site passes the majority of its security checks, this single point of failure overrides the benefits of the other 42 passing tests.

The most business-critical risks stem from this accessibility failure and the lack of proper protocol enforcement. The 403 error suggests a misconfigured firewall or Cloudflare rule that is incorrectly rejecting valid traffic. Additionally, the failure to redirect HTTP traffic to HTTPS creates a window of vulnerability where data could be intercepted or users could be served insecure content, potentially leading to man-in-the-middle attacks. The missing X-Frame-Options header further exposes the site to clickjacking risks, where malicious actors could embed the site in an iframe to trick users into performing unintended actions.

To remediate these issues, the priority should be strictly ordered by impact. First, immediately investigate and resolve the HTTP 403 error by reviewing Cloudflare access rules, WAF settings, or origin server permissions to ensure legitimate traffic is allowed. Second, configure the web server or CDN to enforce a permanent 301 redirect from HTTP to HTTPS to close the protocol gap. Third, address the medium-severity issues by adding the X-Frame-Options header to prevent clickjacking and implementing a DNS CAA record to restrict which Certificate Authorities can issue certificates for the domain. Finally, the low-severity items, such as adding security.txt and various Cross-Origin policy headers, can be addressed in a subsequent maintenance cycle as they pose lower immediate risks.

There are several quick wins that offer high impact with minimal effort. Adding the X-Frame-Options header is a simple configuration change that significantly reduces clickjacking risk. Similarly, publishing a security.txt file is a low-effort task that demonstrates security maturity and provides a clear contact point for security researchers. While the server header disclosure of "cloudflare" is a low-risk information leak, it can be easily masked in the CDN configuration to reduce the attack surface. Focusing on the 403 error and HTTPS redirect first will stabilize the site's availability and security foundation, allowing the team to then layer on the additional protective headers.

Generated by TestPilot-AI Security Audit - automated scan results should be validated by a qualified security professional before remediation sign-off.